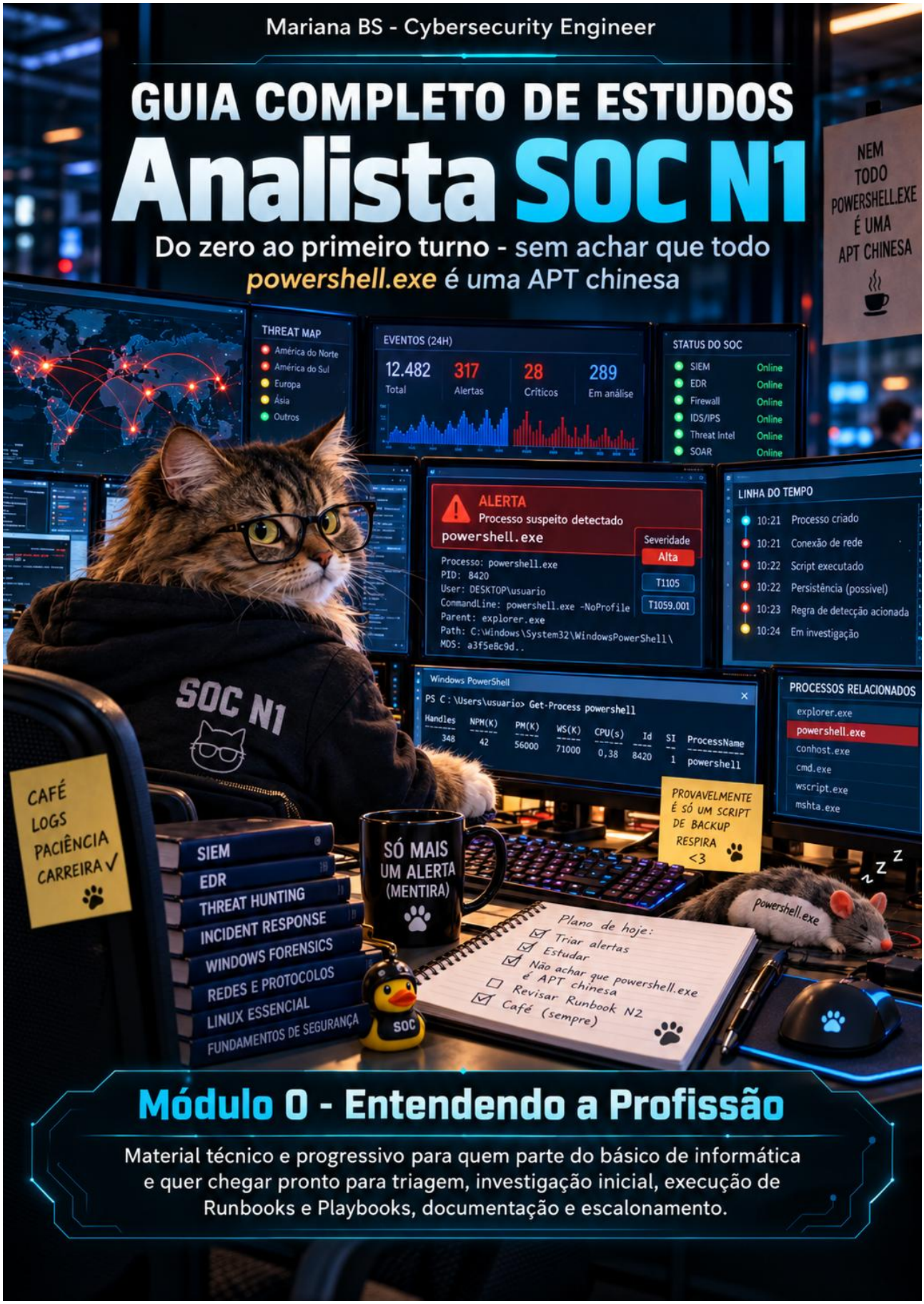

Mariana BS - Cybersecurity Engineer
GUIA COMPLETO DE ESTUDOS
Analista SOC N1
Do zero ao primeiro turno - sem achar que todo powershell.exe é uma APT chinesa
NEM TODO POWERSHELL.EXE É UMA APT CHINESA
THREAT MAP
América do Norte
América do Sul
Europa
Ásia
Outros
EVENTOS (24H)
12.482 Total
317 Alertas
28 Críticos
289 Em análise
STATUS DO SOC
SIEM Online
EDR Online
Firewall Online
IDS/IPS Online
Threat Intel Online
SOAR Online
ALERTA
Processo suspeito detectado
powershell.exe
Severidade
Alta
T1105
T1059.001
Processo: powershell.exe
PID: 8420
User: DESKTOP\usuario
CommandLine: powershell.exe -NoProfile
Parent: explorer.exe
Path: C:\Windows\System32\WindowsPowerShell\
MD5: a3f5e8c9d..
LINHA DO TEMPO
10:21 Processo criado
10:21 Conexão de rede
10:22 Script executado
10:22 Persistência (possível)
10:23 Regra de detecção acionada
10:24 Em investigação
Windows PowerShell
PS C:\Users\usuario> Get-Process powershell
Handles NPM(K) PM(K) WS(K) CPU(s) Id SI ProcessName
348 42 56000 71000 0,38 8420 1 powershell
PROCESSOS RELACIONADOS
explorer.exe
powershell.exe
conhost.exe
cmd.exe
wscript.exe
mshta.exe
SOC N1
CAFÉ
LOGS
PACIÊNCIA
CARREIRA ✓
SIEM
EDR
THREAT HUNTING
INCIDENT RESPONSE
WINDOWS FORENSICS
REDES E PROTOCOLOS
LINUX ESSENCIAL
FUNDAMENTOS DE SEGURANÇA
SÓ MAIS UM ALERTA (MENTIRA)
PROVAVELMENTE É SÓ UM SCRIPT DE BACKUP
RESPIRA <3
Plano de hoje:
Triar alertas
Estudar
Não achar que powershell.exe é APT chinesa
Revisar Runbook N2
Café (sempre)
powershell.exe
SOC
Módulo 0 - Entendendo a Profissão
Material técnico e progressivo para quem parte do básico de informática e quer chegar pronto para triagem, investigação inicial, execução de Runbooks e Playbooks, documentação e escalonamento.

Como usar este guia

Este guia foi escrito para uma pessoa que hoje sabe usar um computador, instalar programas e navegar na internet, e que quer chegar ao nível de trabalhar como **Analista SOC N1**. Ele não é um resumo para decorar na véspera da entrevista. É uma trilha: cada módulo depende do anterior, e os exercícios existem para serem feitos, não admirados.

O foco é **operação defensiva**. Você vai aprender a observar, perguntar, investigar, correlacionar, contextualizar, seguir procedimento, documentar e escalar. Não vai aprender a invadir nada. Quando falarmos de ataques, será sempre do ponto de vista de quem precisa **reconhecer os rastros** que eles deixam.

Como cada módulo está organizado

Sempre que fizer sentido, cada módulo segue a mesma estrutura, para que você saiba onde encontrar cada coisa:

Seção	Para que serve
Objetivo	O que você deve conseguir fazer ao final do módulo.
Conceitos	A teoria: o que é, como funciona, por que existe.
O que um N1 realmente precisa saber	O recorte prático. O que cai na sua mesa de verdade.
Como isso aparece no SOC	Onde o conceito vira alerta, log, ticket ou dor de cabeça.
Exemplos / Logs / Comandos / Ferramentas	Material concreto para ver, digitar e reconhecer.
Exercícios e Laboratório	Prática. As respostas comentadas ficam no fim do módulo.
Perguntas de entrevista	Resposta fraca, resposta boa e o que o entrevistador está avaliando.
Erros comuns / Falsos positivos	Onde iniciantes (e veteranos cansados) tropeçam.
Checklist de domínio	Autoavaliação honesta antes de seguir.
Na vida real / Momento SOC	A distância entre o slide do curso e a fila de alertas às 3h da manhã.

Convenções visuais

> **O QUE UM N1 REALMENTE PRECISA SABER**
> Resumo do que é realmente essencial para o trabalho de N1. Se o tempo estiver curto, comece por essas caixas.

> **NA VIDA REAL**
> A diferença entre a teoria e a operação real. Às vezes engraçada, às vezes triste, quase sempre verdadeira.

MOMENTO SOC

Situações típicas de SOC que ensinam mais que qualquer definição.

DICA

Atalhos, boas práticas e truques de quem já passou por isso.

LABORATÓRIO

Práticas que você executa no seu próprio ambiente de estudos.

Ritmo sugerido

De **1h30 a 2h por dia**. Leia a teoria, faça os exercícios **antes** de olhar as respostas, execute o laboratório e escreva, com suas palavras, as respostas das perguntas de entrevista. Escrever é metade do trabalho de um N1; comece a treinar agora.

Mapa da trilha completa

Bloco	Módulos	Foco
Fundação	0 a 4	Profissão, redes, arquitetura corporativa, Windows, Linux
Visibilidade	5 a 7	Logs, SIEM, EDR/XDR
Identidade e ameaças	8 a 14	Active Directory, e-mail/phishing, malware, IOC/IOA/TTP, MITRE ATT&CK, Threat Intel, ataques comuns
Operação	15 a 24	Triagem, Runbooks, Playbooks, escalonamento, documentação, handover, falsos positivos, SOAR, ITSM/SLA, rotina real
Prática	25 e 26	Laboratório completo e 30+ desafios
Carreira	27 a 33	Entrevista (100+ perguntas), entrevista simulada, CV/LinkedIn, roadmap de 90 dias, primeiro dia e primeiros 30 dias
Referência	Anexos	Não faça isso no SOC, frases que todo N1 vai ouvir, cheat sheets

Sumário

Como usar este guia 2
Módulo 0 — Entendendo a Profissão 5
0.1 Objetivo 5
0.2 Conceitos: o ecossistema da segurança defensiva 5
0.3 Modelos de SOC 8
0.4 Funções dentro e ao redor do SOC 9
0.5 O que se espera de um SOC N1 10
0.6 Vocabulário essencial do SOC 12
0.7 Como isso aparece no SOC 17
0.8 Mais exemplos de classificação 18
0.9 Logs relacionados 19
0.10 Comandos 21
0.11 Ferramentas 21
0.12 Exercícios 22
0.13 Laboratório 23
0.14 Perguntas de entrevista 24
0.15 Erros comuns 26
0.16 Falsos positivos comuns (e confusões de classificação) 27
0.17 Na vida real 27
0.18 Momento SOC 28
0.19 Checklist de domínio 28
0.20 Resumo do módulo 29
0.21 Respostas comentadas dos exercícios 29
Próximo módulo 30

Se o sumário aparecer vazio, clique com o botão direito sobre ele no Word e escolha "Atualizar campo".

Módulo 0 — Entendendo a Profissão

0.1 Objetivo

Antes de aprender protocolo, log ou consulta de SIEM, você precisa saber **onde está pisando**. Ao final deste módulo, você deve conseguir:

- Explicar o que é um SOC e como ele se diferencia de CSIRT, CERT, NOC, DFIR, Threat Hunting e Threat Intelligence.
- Descrever as funções de N1, N2, N3, SOC Lead, Incident Responder, Threat Hunter, Detection Engineer, SIEM Engineer e SOC Manager.
- Dizer com clareza o que se espera de um N1, o que ele **não** faz e o que ele só faz **com autorização**.
- Usar corretamente o vocabulário básico: evento, alerta, caso, incidente, falso positivo, verdadeiro positivo, benigno positivo, IOC, IOA, TTP, telemetria, evidência, contexto, severidade e criticidade.
- Classificar um alerta simples usando esse vocabulário e justificar a classificação.

0.2 Conceitos: o ecossistema da segurança defensiva

Segurança da informação tem muitas siglas, e boa parte delas se sobrepõe. Em empresas pequenas, uma única equipe de três pessoas faz tudo. Em empresas grandes, cada sigla é um andar diferente, com um gerente diferente e uma ferramenta diferente que não conversa com a do andar de cima. O importante é entender **a função**, não o nome da sala.



Figura 1 — O ecossistema da segurança defensiva e a pergunta de cada área

SOC — Security Operations Center

O que é: a equipe (e o conjunto de processos e ferramentas) responsável por **monitorar continuamente** o ambiente em busca de atividade maliciosa ou suspeita, **analisar** o que for detectado e **coordenar a resposta inicial**.

Como funciona: o ambiente gera registros (logs e telemetria) em firewalls, servidores, estações, nuvem, e-mail, VPN e aplicações. Esses registros são enviados a plataformas como SIEM e EDR, que aplicam regras de detecção. Quando uma regra dispara, nasce um **alerta**. O SOC recebe, analisa, classifica, documenta e decide o próximo passo: fechar com justificativa, conter conforme procedimento ou escalar.

Por que existe: porque ataques acontecem a qualquer hora, e o tempo entre o primeiro sinal e a reação define o tamanho do prejuízo. Um phishing identificado em 10 minutos é um ticket. O mesmo phishing descoberto 40 dias depois pode ser um ransomware com comunicado à imprensa.

Onde aparece: como equipe interna da empresa, como serviço terceirizado (MSSP/MDR) atendendo vários clientes, ou em modelo híbrido.

CSIRT — Computer Security Incident Response Team

O que é: equipe focada em **responder a incidentes** de segurança: conter, erradicar, recuperar e aprender com o ocorrido. Enquanto o SOC vigia e detecta, o CSIRT entra quando a coisa ficou séria.

Na prática: em muitas organizações o CSIRT é o "N3" do SOC, ou um time separado acionado pelo SOC. Em outras, CSIRT e SOC são o mesmo grupo de pessoas usando crachás diferentes dependendo da reunião.

CERT — Computer Emergency Response Team

O que é: historicamente, o nome de equipes de resposta com atuação mais ampla, muitas vezes **nacional ou setorial**, que coordenam incidentes, publicam alertas e compartilham informação entre organizações. "CERT" é uma marca registrada ligada à Carnegie Mellon; por isso muitas equipes usam "CSIRT".

Exemplo brasileiro: o **CERT.br** (mantido pelo NIC.br) recebe notificações de incidentes envolvendo redes brasileiras, publica estatísticas e materiais de boas práticas. O **CTIR Gov** cumpre papel semelhante para a administração pública federal.

Para o N1: você vai consumir alertas e boletins de CERTs como fonte de inteligência e, eventualmente, ver sua empresa notificar ou ser notificada por eles, sempre via processo definido pela gestão.

Blue Team

O que é: termo guarda-chuva para quem **defende**. SOC, resposta a incidentes, engenharia de detecção, hardening, gestão de vulnerabilidades: tudo isso é Blue Team. Surge por oposição ao **Red Team**, que simula adversários. Quando os dois trabalham juntos de forma colaborativa, fala-se em **Purple Team**.

Threat Hunting

O que é: busca **proativa** por ameaças que **não** geraram alerta. O hunter parte de uma hipótese ("se um atacante estivesse usando contas de serviço para se mover lateralmente, que rastros deixaria?") e vai aos dados procurar.

Diferença para o N1: o N1 é **reativo** por natureza: trabalha a fila de alertas. O hunter é proativo: procura o que as regras não pegaram. Os achados do hunting frequentemente viram **novas regras de detecção**, que viram alertas, que caem na fila do N1. O ciclo se fecha.

DFIR — Digital Forensics and Incident Response

O que é: a combinação de **forense digital** (coletar, preservar e analisar evidências de forma que resistam a questionamentos, inclusive jurídicos) com **resposta a incidentes**. Análise de memória, imagem de disco, linha do tempo detalhada, cadeia de custódia.

Para o N1: você não fará forense, mas suas ações afetam a forense. Reiniciar uma máquina "para ver se resolve" apaga a memória RAM, onde muitas vezes estava a melhor evidência. Documentar o que você fez, quando e por quê é o que permite ao DFIR confiar no trabalho do SOC.

Threat Intelligence (CTI — Cyber Threat Intelligence)

O que é: coleta, análise e disseminação de informação sobre **ameaças e adversários**: quem ataca, com que objetivo, usando que técnicas e infraestrutura. Dado bruto (um IP) não é inteligência; inteligência é o dado **com contexto e utilidade** ("esse IP pertence a infraestrutura usada por um grupo que ataca o setor financeiro brasileiro com phishing de boleto").

Para o N1: você consome CTI o tempo todo ao **enriquecer** indicadores: reputação de IP, idade de domínio, detecções de hash. Veremos isso a fundo no Módulo 13.

NOC — Network Operations Center

O que é: centro que monitora **disponibilidade e desempenho** de rede e infraestrutura. A pergunta do NOC é "está funcionando?". A pergunta do SOC é "está sendo abusado?".

Aspecto	NOC	SOC
Pergunta central	Está no ar? Está rápido?	Está seguro? Isso é esperado?
Exemplo de alerta	Link principal com 95% de uso	Host enviando 4 GB para IP desconhecido às 3h
Métrica típica	Uptime, latência, perda de pacotes	Tempo de detecção, tempo de resposta
Inimigo	Falha, gargalo, erro de configuração	Adversário (ou erro que parece adversário)
Ponto de encontro	Pico de tráfego: backup mal agendado?	Pico de tráfego: exfiltração?

> **NA VIDA REAL**
>
> Link saturado às 2h da manhã.
>
> NOC: "Deve ser backup."
>
> SOC: "Deve ser exfiltração."
>
> Backup: "Eu nem estou agendado para hoje."
>
> É por isso que NOC e SOC precisam conversar. E é por isso que raramente conversam.

Security Operations (SecOps)

O que é: o conjunto das atividades operacionais de segurança do dia a dia: monitoramento, resposta, gestão de vulnerabilidades, gestão de acessos, operação de ferramentas. O SOC é o coração do SecOps,

mas não é tudo. "SecOps" também é usado para designar a colaboração entre equipes de segurança e operação de TI.

Resumo comparativo

Termo	Pergunta que responde	Postura	Relação com o N1
SOC	O que está acontecendo agora?	Reativa + contínua	É onde o N1 trabalha
CSIRT	Como contemos e recuperamos?	Resposta	Recebe escalonamentos
CERT	O que está acontecendo no país/setor?	Coordenação	Fonte de alertas e boletins
Blue Team	Como defendemos?	Defensiva ampla	O N1 faz parte
Threat Hunting	O que as regras não viram?	Proativa	Gera novas detecções para a fila
DFIR	O que exatamente aconteceu e como provar?	Investigativa profunda	Depende da preservação feita pelo SOC
CTI	Quem é o adversário e o que ele faz?	Analítica	Fornece contexto para enriquecimento
NOC	Está funcionando?	Disponibilidade	Parceiro (e às vezes culpado) em casos de rede

0.3 Modelos de SOC

Onde você vai trabalhar muda bastante o seu dia a dia. Conheça os modelos mais comuns:

Modelo	Como funciona	Vantagens para o N1	Desafios para o N1
SOC interno	Equipe da própria empresa monitora apenas o ambiente dela.	Conhece bem o ambiente, sabe quem é quem, acesso mais fácil ao time de TI.	Menos variedade de casos; às vezes equipe pequena.
MSSP / MDR	Empresa de serviços monitora vários clientes.	Muita variedade, aprendizado rápido, várias ferramentas.	Cada cliente tem regras, SLAs, contatos e caos próprios. Contexto limitado.
Híbrido	Parte interna, parte terceirizada (ex.: terceiro faz 24x7 N1, time interno faz N2/N3).	Divisão clara de papéis.	Handover entre empresas; responsabilidade às vezes nebulosa.
SOC virtual	Equipe distribuída, sem sala física.	Trabalho remoto.	Comunicação precisa ser muito disciplinada.

Muitos SOCs operam **24x7** em turnos (por exemplo 6x18 ou escalas 12x36). Isso torna o **handover de turno** (Módulo 20) uma habilidade crítica: o incidente não se importa que você foi embora às 19h.

> **NA VIDA REAL**
>
> Cliente A: SIEM Sentinel, EDR Defender, tickets no ServiceNow, escalonamento por telefone.
>
> Cliente B: Splunk, CrowdStrike, Jira, escalonamento por e-mail "com cópia para o diretor".

> Cliente C: Wazuh, "EDR em implantação desde 2022", tickets numa planilha compartilhada chamada FINAL_v3_agora_vai.xlsx.
>
> Bem-vindo ao MSSP. Aqui você aprende rápido porque não tem alternativa.

0.4 Funções dentro e ao redor do SOC

Os nomes variam de empresa para empresa ("Analista de Monitoramento", "Cyber Defense Analyst", "Analista de Segurança Jr."), mas as responsabilidades costumam seguir este desenho:

Fluxo típico de um alerta pelos níveis

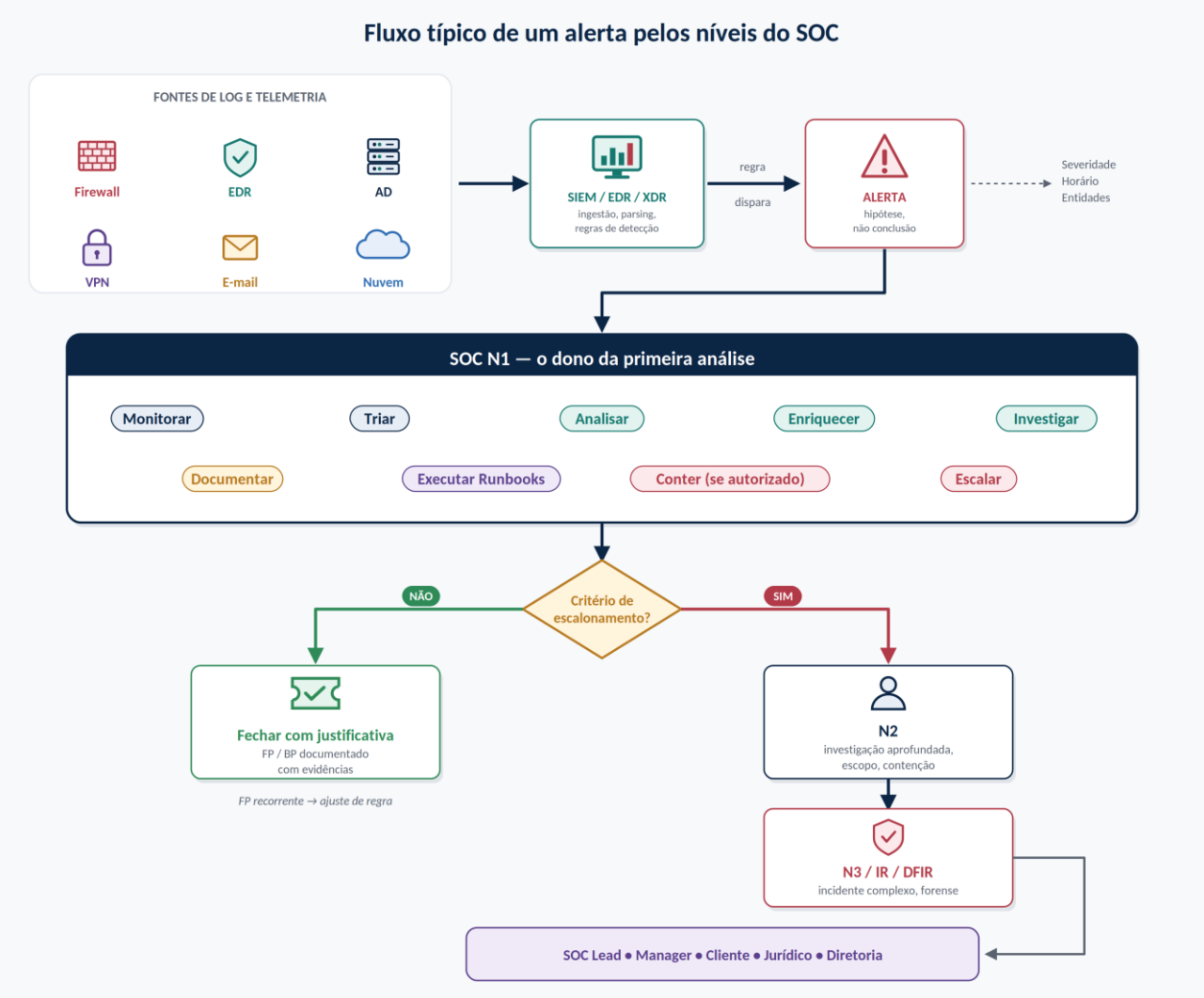


Figura 2 — Fluxo típico de um alerta pelos níveis do SOC

As funções em detalhe

Função	O que faz	Entregas típicas	Quem ele chama
SOC N1	Monitoramento, triagem, enriquecimento, investigação inicial, execução de Runbooks/Playbooks, documentação, contenção autorizada, escalonamento.	Tickets bem documentados, classificação justificada, escalonamentos com evidência.	N2, SOC Lead, owner do ativo (conforme processo).

Função	O que faz	Entregas típicas	Quem ele chama
SOC N2	Investigação aprofundada de casos escalados, correlação ampla, definição de escopo, recomendação de contenção, ajuste inicial de falsos positivos.	Análise de causa provável, escopo, recomendações.	N3/IR, Lead, times de TI.
SOC N3	Casos complexos, análise avançada (malware, memória, técnicas de adversário), apoio técnico aos níveis anteriores, às vezes hunting.	Relatórios técnicos, novas detecções, orientação.	IR, Detection Engineering, gestão.
SOC Lead	Coordena o turno ou a equipe, distribui trabalho, garante qualidade e SLA, é o ponto de decisão em situações ambíguas.	Priorização, revisão de tickets, comunicação de incidentes.	Manager, clientes, IR.
Incident Responder	Conduz a resposta a incidentes confirmados: contenção, erradicação, recuperação, lições aprendidas.	Plano de resposta, relatório de incidente.	Jurídico, TI, gestão, DFIR.
Threat Hunter	Busca proativa baseada em hipóteses e inteligência.	Achados de hunting, hipóteses documentadas, sugestões de detecção.	Detection Engineering, IR.
Detection Engineer	Cria, testa, ajusta e mantém regras de detecção; reduz ruído; mapeia cobertura (ex.: MITRE ATT&CK).	Regras, lógica de correlação, documentação de detecção.	SIEM Engineer, N2/N3.
SIEM Engineer	Mantém a plataforma: ingestão, parsers, conectores, retenção, desempenho, saúde das integrações.	Fontes integradas, parsing correto, dashboards de saúde.	Times de infraestrutura e fornecedores.
SOC Manager	Estratégia, orçamento, pessoas, métricas, relacionamento com diretoria e clientes, processos.	Relatórios executivos, metas, contratação.	Diretoria, CISO, clientes.

> **DICA**
>
> Na sua primeira semana, descubra **o nome e o contato** de quem ocupa cada uma dessas funções no seu SOC. Organograma é decoração; saber quem atende o telefone às 3h da manhã é sobrevivência.

0.5 O que se espera de um SOC N1

Aqui está o ponto mais importante do módulo. Muita gente entra na área achando que N1 é um "hacker júnior". Não é. **SOC N1 não é pentester júnior.** O N1 não explora vulnerabilidades, não roda ferramentas ofensivas contra sistemas e não "invade para testar". O trabalho é defensivo, analítico e fortemente guiado por procedimento.

> **O QUE UM N1 REALMENTE PRECISA SABER**
>
> O trabalho do N1 cabe em nove verbos:
>
> - **Monitorar**: acompanhar filas, dashboards e a saúde das fontes de log.
> - **Triar**: decidir rapidamente o que é urgente, o que é ruído e o que precisa de análise.
> - **Analisar**: ler o alerta e os eventos que o originaram, entendendo o que de fato aconteceu.

- **Enriquecer**: adicionar contexto (quem é o usuário, que ativo é esse, qual a reputação do IP).
- **Investigar (inicial)**: buscar eventos relacionados, montar uma linha do tempo curta, responder quem/o quê/quando/onde/como.
- **Documentar**: registrar evidências, raciocínio e conclusão de forma que outra pessoa entenda.
- **Executar procedimentos**: seguir Runbooks e Playbooks.
- **Conter (se autorizado)**: executar ações de contenção **previstas e autorizadas** (ex.: isolar endpoint em cenário definido).
- **Escalar**: acionar N2/IR/gestão quando os critérios forem atingidos, com evidência, não com pânico.

Faz, faz com autorização, não faz

O N1 normalmente FAZ	O N1 faz SÓ COM AUTORIZAÇÃO/PROCEDIMENTO	O N1 normalmente NÃO FAZ
Consultar logs no SIEM	Isolar um endpoint no EDR	Alterar regras do SIEM em produção
Analisar árvore de processos no EDR	Solicitar/executar bloqueio de IP ou domínio	Executar malware para "ver o que faz"
Consultar reputação de IP, domínio, hash	Solicitar reset de senha ou desabilitar conta	Reiniciar servidores
Montar timeline inicial	Remover e-mail malicioso das caixas	Contatar diretamente o atacante (sim, já aconteceu)
Documentar e classificar alertas	Comunicar clientes (conforme matriz)	Declarar oficialmente "fomos hackeados"
Abrir, atualizar e escalar tickets	Coletar artefatos de um host	Subir arquivo confidencial em serviço público de análise
Verificar saúde de fontes de log	Encerrar sessão de usuário	Fazer pentest no ambiente

NA VIDA REAL

Nem todo PowerShell é ataque.

Se você bloquear todo PowerShell da empresa no primeiro dia, talvez o próximo incidente investigado pelo SOC seja o seu desligamento.

Metade da TI administra o ambiente com PowerShell. A outra metade administra com scripts em PowerShell escritos em 2016 por alguém que já saiu da empresa.

Competências que diferenciam um bom N1

- **Curiosidade disciplinada:** perguntar "por quê?" até entender, mas dentro do tempo e do escopo do alerta.
- **Leitura atenta:** a resposta costuma estar no log, num campo que ninguém leu (a command line, o logon type, o parent process).
- **Escrita clara:** se você investigou e não documentou, para o resto do SOC você não investigou.
- **Humildade técnica:** dizer "não sei, vou verificar" em vez de chutar uma conclusão.

- **Calma:** severidade alta no alerta não significa incidente confirmado. Significa "olhe com prioridade".
- **Respeito a processo:** o Runbook existe para que decisões críticas não dependam do humor de quem está de plantão.
- **Fundamentos sólidos:** redes, sistemas operacionais e logs. Por isso os próximos módulos existem.

0.6 Vocabulário essencial do SOC

Estes termos vão aparecer em toda conversa, ticket, entrevista e reunião. Use-os com precisão: chamar todo alerta de "incidente" é o equivalente profissional a gritar "fogo" toda vez que alguém acende uma vela.

Evento

O que é: qualquer ocorrência observável registrada em um sistema. Um login, uma conexão de rede, um processo iniciado, um arquivo criado. A esmagadora maioria dos eventos é normal.

Exemplo: o Windows registra o Event ID 4624 (logon bem-sucedido) quando `maria.souza` faz login às 08:02.

Volume: um ambiente médio gera **milhões** de eventos por dia. Ninguém olha eventos um a um; por isso existem regras.

Alerta

O que é: uma notificação gerada quando um ou mais eventos atendem a uma **regra de detecção**. O alerta é uma **hipótese**, não uma conclusão. Ele diz "isso merece atenção", não "isso é ataque".

Exemplo: a regra "mais de 20 falhas de login (4625) para o mesmo usuário em 5 minutos" dispara para `maria.souza`.

Caso

O que é: o contêiner de trabalho da investigação. Um caso pode agrupar vários alertas relacionados, evidências, anotações e ações. Em muitas ferramentas "caso", "ticket" e "incident" (em inglês, no sentido de registro) se misturam; o importante é o conceito: **é onde a investigação vive**.

Exemplo: três alertas (falhas de login, login bem-sucedido de IP estrangeiro e criação de regra de encaminhamento de e-mail) agrupados num único caso "Possível comprometimento da conta maria.souza".

Incidente

O que é: um evento ou conjunto de eventos que **compromete ou ameaça de fato** a confidencialidade, integridade ou disponibilidade de informações ou sistemas, ou que viola políticas de segurança. Declarar um incidente geralmente aciona processos formais (resposta, comunicação, às vezes jurídico e regulatório).

Atenção: quem **declara** incidente costuma ser N2, Lead ou IR, conforme política. O N1 **identifica indícios e escala**.

A pirâmide: do ruído ao incidente

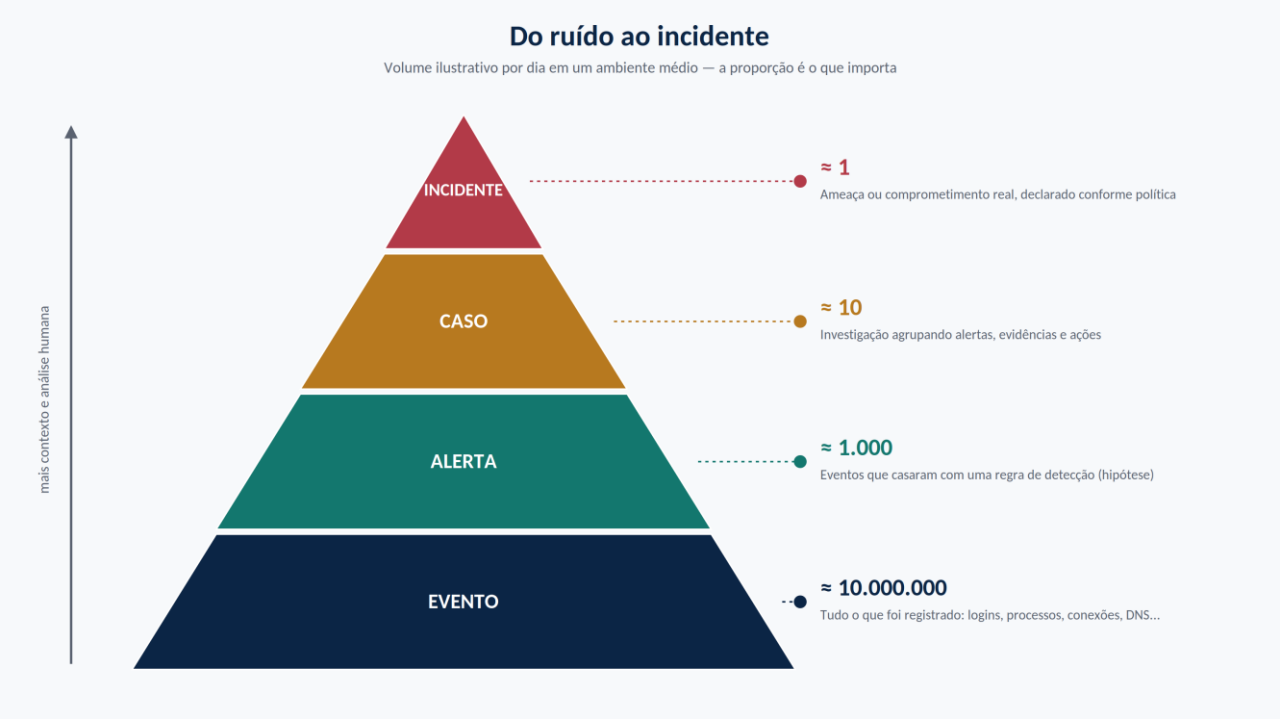


Figura 3 — Do evento ao incidente: cada camada exige mais contexto e análise humana

Classificação: verdadeiro, falso e benigno

Todo alerta, ao final da análise, recebe uma classificação. A matriz clássica cruza **o que a regra disse** com **o que realmente aconteceu**:

	Atividade maliciosa ocorreu	Atividade maliciosa NÃO ocorreu
Alerta disparou	**Verdadeiro Positivo (VP / TP)** A regra acertou: é ataque ou atividade maliciosa real.	**Falso Positivo (FP)** A regra disparou, mas não havia nada malicioso.
Alerta NÃO disparou	**Falso Negativo (FN)** Houve ataque e ninguém viu. O pior cenário.	**Verdadeiro Negativo (VN / TN)** Nada aconteceu e nada disparou. O cenário tedioso e desejado.

Na prática, a maioria dos SOCs usa uma terceira categoria muito importante:

Benigno Positivo (BP), também chamado de "True Positive Benign": a regra **acertou tecnicamente** (a atividade descrita realmente aconteceu), mas a atividade é **legítima e esperada**. Exemplo: a regra "execução de ferramenta de acesso remoto" dispara porque o suporte usou a ferramenta aprovada para atender um usuário. A regra não errou; o comportamento é que é autorizado.

Classificação	A atividade detectada aconteceu?	É maliciosa?	Exemplo
Verdadeiro Positivo	Sim	Sim	PowerShell baixando e executando payload de domínio registrado há 2 dias, iniciado pelo Word.
Benigno Positivo	Sim	Não (autorizada/esperada)	Scanner de vulnerabilidades da própria empresa gerando alerta de port scan, em janela aprovada.

Classificação	A atividade detectada aconteceu?	É maliciosa?	Exemplo
Falso Positivo	Não (a regra interpretou errado)	Não	Regra de "login de país incomum" disparando porque a base de geolocalização classificou um IP brasileiro como holandês.

> 🎯 **O QUE UM N1 REALMENTE PRECISA SABER**
>
> A diferença entre **falso positivo** e **benigno positivo** parece preciosismo, mas muda a ação:
>
> - **FP** indica que a **regra** ou a **fonte** tem problema. Ação sugerida: ajuste de lógica, parser ou enriquecimento (encaminhado ao Detection/SIEM Engineer).
> - **BP** indica que a regra funciona, mas falta **contexto de exceção**. Ação sugerida: documentar a atividade legítima e, se recorrente, propor exceção controlada.
>
> Em qualquer um dos dois: **explique por quê**. "É FP" sem justificativa não é classificação; é opinião.

IOC — Indicator of Compromise

O que é: um artefato observável que indica que um comprometimento **pode ter ocorrido**. Endereço IP, domínio, URL, hash de arquivo, nome de arquivo, chave de registro, endereço de e-mail remetente, mutex.

Característica crucial: IOCs são **reativos e perecíveis**. O atacante troca de IP e de domínio com facilidade; o hash muda se um único byte do arquivo muda. Um IP malicioso hoje pode ser de um provedor de nuvem legítimo amanhã.

Exemplo: o hash SHA-256 de um instalador malicioso divulgado num boletim de inteligência.

IOA — Indicator of Attack

O que é: um indicador de **comportamento** que sugere um ataque **em andamento**, independentemente da ferramenta ou infraestrutura usada. O foco é na ação, não no artefato.

Exemplo: um processo do Office (`winword.exe`) iniciando `powershell.exe` com comando codificado em Base64 e fazendo conexão de rede externa. Não importa o hash nem o IP: o **comportamento** é o sinal.

TTP — Tactics, Techniques and Procedures

O que é: a descrição de **como** um adversário opera, em três níveis:

- **Tática:** o objetivo naquele momento ("por quê"). Ex.: obter acesso a credenciais.
- **Técnica:** o método geral para atingir o objetivo ("como"). Ex.: extrair credenciais da memória do processo LSASS.
- **Procedimento:** a implementação específica usada por um grupo ("exatamente como"). Ex.: o grupo X usa determinada ferramenta com determinados parâmetros, sempre às sextas à noite.

TTPs são a base do framework **MITRE ATT&CK** (Módulo 12). Mudar de TTP é caro para o atacante; mudar de IP é barato. Por isso detectar comportamento vale mais que colecionar IPs.

	IOC	IOA	TTP
Foco	Artefato (o quê ficou)	Comportamento (o que está acontecendo)	Modo de operação (como o adversário age)

	IOC	IOA	TTP
Tempo	Geralmente após o fato	Durante	Descreve padrão ao longo do tempo
Exemplo	Hash, IP, domínio	Office gerando PowerShell ofuscado	Phishing com anexo → macro → PowerShell → roubo de credenciais
Durabilidade	Baixa	Média/alta	Alta
Custo para o atacante mudar	Baixo	Médio	Alto

Telemetria

O que é: o fluxo contínuo de dados que sistemas e sensores enviam sobre o que está acontecendo: eventos de processo, conexões, logins, consultas DNS, alterações de arquivos. Log é um tipo de telemetria; "telemetria" costuma ser usado de forma mais ampla, especialmente para dados de EDR e sensores de rede.

Por que importa: sem telemetria, não há detecção nem investigação. Um host sem agente de EDR e sem envio de logs é um ponto cego: se algo acontecer lá, você vai descobrir pelo usuário ou pelo atacante, nessa ordem de preferência.

Evidência

O que é: qualquer dado que sustenta uma conclusão da investigação: um trecho de log, um print da árvore de processos, o resultado de reputação de um hash, o header de um e-mail. Evidência precisa ser **identificável** (de onde veio), **datada** (quando), **reprodutível** (qual consulta gerou) e **preservada** (não alterada).

Regra de ouro do N1: toda afirmação no ticket deve apontar para uma evidência. "O usuário não reconhece o login" é evidência se você registrou quem confirmou, quando e por qual canal.

Contexto

O que é: a informação que transforma um evento isolado em algo interpretável. Quem é o usuário (cargo, área, horário habitual)? Que ativo é esse (servidor de produção, estação do RH, máquina de laboratório)? Existe mudança aprovada? Esse comportamento já aconteceu antes?

Por que é tudo: o mesmo evento, "conta criou nova tarefa agendada no servidor", é rotina para o time de infraestrutura numa janela de manutenção e é muito suspeito às 3h da manhã a partir de uma conta de estagiário.

Severidade x Criticidade

Dois conceitos que iniciantes confundem o tempo todo:

Conceito	Pergunta	Refere-se a	Exemplo
Severidade	Quão grave é esta ameaça/atividade se for real?	O **alerta / a ameaça**	Execução de ransomware = severidade crítica. Uma varredura de portas externa = severidade baixa.

Conceito	Pergunta	Refere-se a	Exemplo
Criticidade	Quão importante é este ativo/usuário para o negócio?	O **ativo / a identidade**	Controlador de domínio ou servidor de pagamentos = criticidade alta. Máquina de laboratório isolada = baixa.

A **prioridade** de atendimento costuma combinar os dois (mais a confiança na detecção). Um alerta de severidade média num controlador de domínio pode merecer mais urgência que um alerta de severidade alta numa VM de teste desligada da rede. Veremos matrizes completas no Módulo 18.

> **MOMENTO SOC**
>
> Alerta: severidade CRÍTICA.
>
> Ativo: "SRV-TESTE-OLD-02".
>
> CMDB: sem owner, criticidade não informada.
>
> EDR: último contato há 213 dias.
>
> SIEM: continua recebendo log dele.
>
> Antes de discutir a severidade, você vai descobrir que ninguém sabe se essa máquina existe. E a sua próxima hora será dedicada a isso.

Glossário rápido

Termo	Definição em uma frase
Evento	Qualquer ocorrência registrada por um sistema.
Alerta	Notificação gerada quando eventos casam com uma regra; é uma hipótese.
Caso	Onde a investigação vive: agrupa alertas, evidências e ações.
Incidente	Ameaça ou comprometimento real à segurança, declarado conforme política.
Verdadeiro positivo	O alerta apontou atividade maliciosa real.
Falso positivo	O alerta disparou, mas a atividade descrita não é o que parece / a regra errou.
Benigno positivo	A atividade aconteceu, mas é legítima e esperada.
Falso negativo	Atividade maliciosa que não gerou alerta.
IOC	Artefato que indica possível comprometimento (IP, hash, domínio...).
IOA	Comportamento que indica ataque em andamento.
TTP	Táticas, técnicas e procedimentos: como o adversário opera.
Telemetria	Fluxo contínuo de dados de sistemas e sensores.
Evidência	Dado identificável, datado e preservado que sustenta uma conclusão.
Contexto	Informação que permite interpretar se um evento é esperado.
Severidade	Gravidade da ameaça se ela for real.
Criticidade	Importância do ativo ou identidade para o negócio.

0.7 Como isso aparece no SOC

Vamos juntar tudo acompanhando o **ciclo de vida de um alerta**:



Figura 4 — Ciclo de vida de um alerta: da geração do evento à retroalimentação

Exemplo guiado: o alerta de força bruta

Alerta recebido: `Multiple Failed Logons - Single Account` — severidade Média — 14/09 02:17 (UTC-3).

```
Regra:        > 20 eventos 4625 para a mesma conta em 5 minutos
Conta:        CORP\joao.pereira
Host destino: SRV-FILE-01 (servidor de arquivos)
IP origem:    10.20.30.45
Contagem:     148 falhas entre 02:12 e 02:17
Logon Type:   3 (rede)
Status:       0xC000006A (senha incorreta)
```

Veja como o vocabulário se encaixa:

- **Eventos:** 148 registros 4625 no servidor.
- **Alerta:** a regra agregou esses eventos e gerou uma notificação.
- **Telemetria disponível:** logs de segurança do Windows do servidor. Temos EDR no host `10.20.30.45`? Temos log de DHCP para saber que máquina é essa?
- **Contexto a buscar:** que máquina tem o IP 10.20.30.45 naquele horário? Quem é João? Ele trabalha de madrugada? Houve troca de senha recente? Existe algum serviço ou tarefa agendada usando a conta dele?
- **Criticidade:** servidor de arquivos, com dados de várias áreas: média/alta.

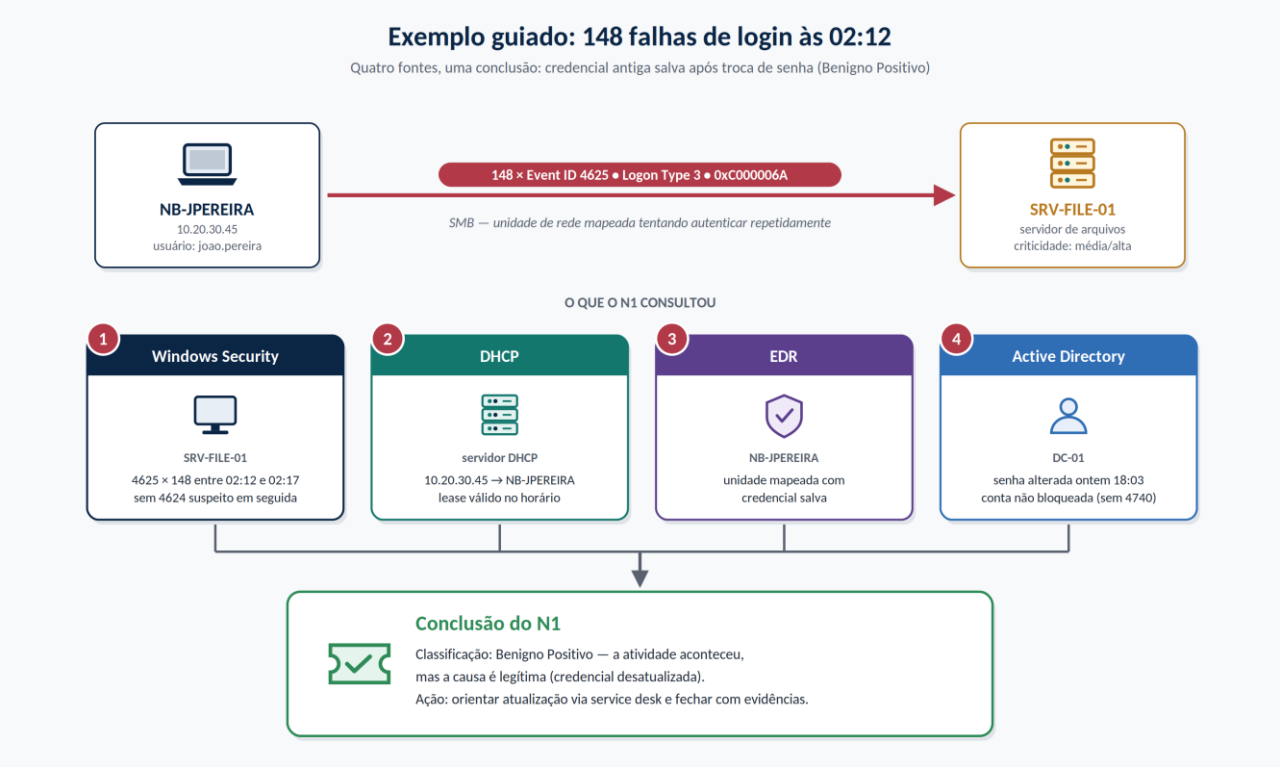


Figura 5 — Exemplo guiado: quatro fontes consultadas para classificar o alerta

Investigação (resumida): o log de DHCP mostra que `10.20.30.45` é o notebook `NB-JPEREIRA`. O EDR mostra uma unidade de rede mapeada com credencial salva. O AD mostra que a senha de João foi alterada ontem às 18h. Não há login bem-sucedido suspeito, nem outras contas envolvidas, nem conexões externas anômalas.

Classificação: Benigno Positivo (a atividade detectada, falhas repetidas de login, aconteceu de fato; a causa é credencial antiga salva no mapeamento de rede após troca de senha). Não é falso positivo, porque a regra não errou.

Ação: documentar evidências, orientar via canal definido (ex.: service desk) a atualização da credencial salva, verificar se a conta foi bloqueada (Event ID 4740) e fechar com justificativa.

Quando seria escalado? Se as falhas viessem de IP externo ou de host desconhecido; se houvesse muitas contas diferentes a partir da mesma origem (indício de password spraying); se houvesse um login bem-sucedido logo após as falhas a partir de origem incomum; ou se o host de origem mostrasse processos suspeitos.

> **DICA**
>
> Repare que, neste exemplo, **quase nada do trabalho foi "hackear"**. Foi ler campos, cruzar três fontes (Windows, DHCP, EDR) e consultar uma quarta (AD). Esse é o N1.

0.8 Mais exemplos de classificação

Cenário	Classificação provável	Justificativa	Próximo passo
Alerta "Port scan interno" a partir de 10.1.1.50, que é o servidor do scanner de vulnerabilidades, em janela de varredura aprovada.	Benigno Positivo	A varredura aconteceu; origem e janela são autorizadas e documentadas.	Fechar citando o ativo, a janela e a referência da aprovação.
Alerta "Login de país incomum" para usuário no Brasil; o IP pertence a operadora brasileira, mas a base GeoIP está desatualizada.	Falso Positivo	A atividade "login de outro país" não ocorreu; o enriquecimento errou.	Fechar com evidência (ASN/WHOIS) e reportar a falha de enriquecimento.
`excel.exe` gerou `powershell.exe -enc ...` que conectou a domínio com 3 dias de existência.	Suspeito → provável Verdadeiro Positivo	Office gerando PowerShell ofuscado com conexão a domínio recém-criado é IOA clássico.	Seguir Playbook de malware/PowerShell; escalar para N2; isolar apenas se o procedimento autorizar.
Alerta "Nova conta criada" num horário comercial, feita pela conta do time de identidade, com ticket de admissão correspondente.	Benigno Positivo	Criação legítima, rastreável a solicitação.	Fechar referenciando o chamado de admissão.
Alerta de "Logs pararam de chegar" do firewall de borda.	Não é FP/VP de ameaça: é **problema operacional de visibilidade**	Perda de telemetria cria ponto cego.	Executar Runbook de saúde de fonte; acionar SIEM Engineer/infra; registrar no handover.

0.9 Logs relacionados

Este módulo é conceitual, mas vale conhecer desde já as grandes famílias de fontes que um SOC consome. Cada uma será aprofundada nos próximos módulos.

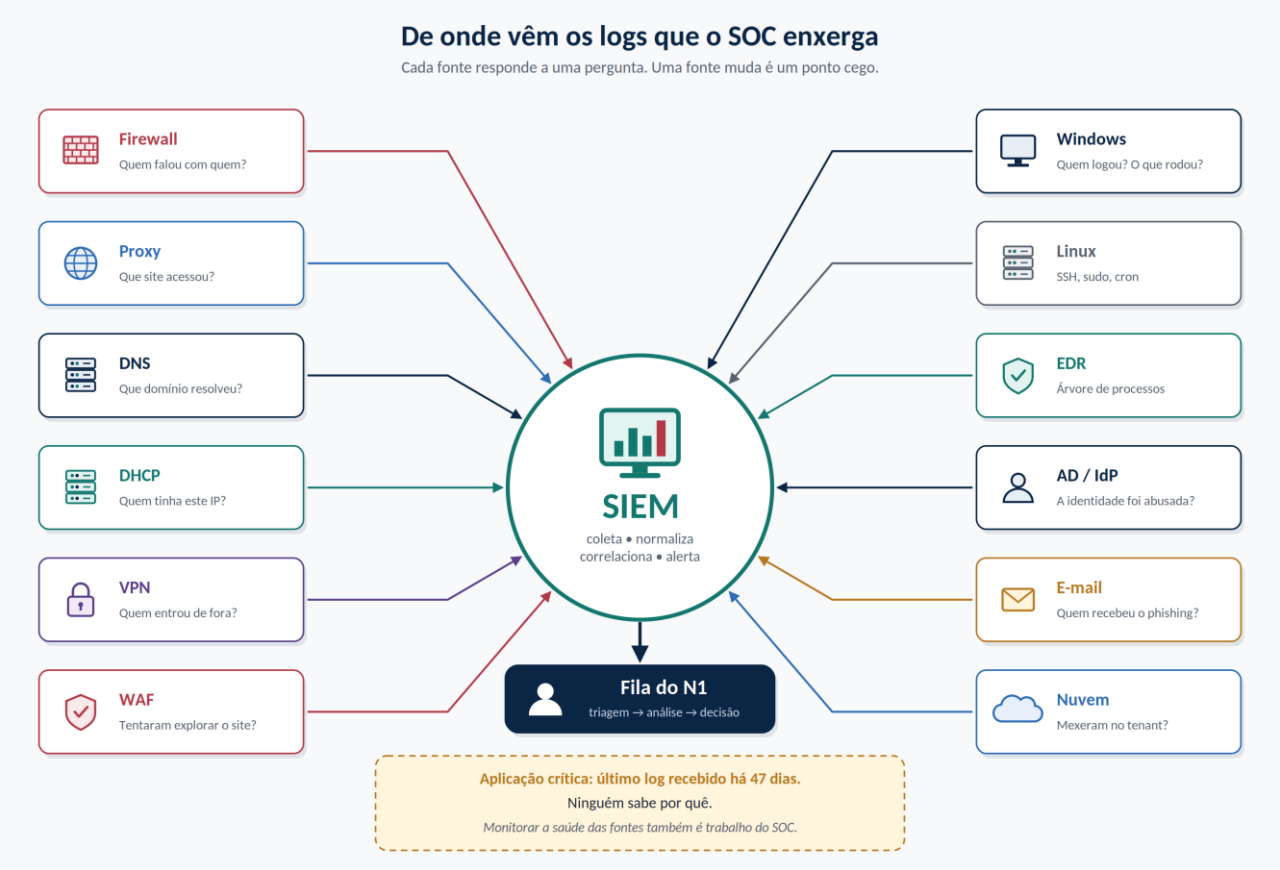


Figura 6 — As principais fontes de log de um SOC e a pergunta que cada uma responde

Fonte	O que mostra	Pergunta que ajuda a responder	Módulo
Firewall	Conexões permitidas e bloqueadas, origem, destino, portas	Quem falou com quem?	1 e 5
Proxy / filtro web	URLs acessadas, categoria, usuário, user-agent	Que site o usuário acessou?	1 e 5
DNS	Nomes consultados e respostas	Que domínio a máquina tentou resolver?	1 e 5
DHCP	Qual IP foi entregue a qual MAC/hostname	Que máquina tinha este IP naquela hora?	1 e 5
VPN	Logins remotos, IP público, duração	Quem entrou de fora e de onde?	1 e 5
Windows (Security, System...)	Logons, processos, serviços, contas	Quem logou? O que executou?	3
Linux (auth, syslog, journald)	SSH, sudo, serviços, cron	Quem acessou? Quem virou root?	4
EDR	Processos, árvore, command line, rede, arquivos	O que rodou no endpoint e quem iniciou?	7
Active Directory / IdP	Autenticação, Kerberos, alterações de grupos	A identidade foi abusada?	8
E-mail (gateway)	Remetente, destinatário, anexos, veredito	Quem recebeu o phishing?	9

Fonte	O que mostra	Pergunta que ajuda a responder	Módulo
WAF	Requisições HTTP bloqueadas/permitidas, assinaturas	Tentaram explorar a aplicação?	5 e 14
Nuvem (M365, Azure, AWS, GCP)	Logins, alterações de configuração, acesso a dados	Alguém mexeu na nuvem?	5 e 6

> **NA VIDA REAL**
>
> No curso: "O SIEM centraliza os logs da organização."
>
> Na vida real:
>
> Firewall manda log.
>
> EDR manda log.
>
> VPN talvez mande log.
>
> A aplicação crítica parou de mandar há 47 dias.
>
> Ninguém sabe por quê.
>
> Bem-vindo ao SOC.

0.10 Comandos

Ainda é cedo para comandos de investigação, mas você já pode começar a se familiarizar com o terminal. Estes comandos respondem à pergunta mais básica de qualquer análise: **em que máquina estou e quem sou eu nela?**

Windows (Prompt de Comando ou PowerShell)

```
whoami              # usuário atual (DOMINIO\usuario)
whoami /groups      # grupos do usuário (útil para saber privilégios)
hostname            # nome da máquina
ipconfig /all       # IPs, MAC, gateway, DNS, servidor DHCP
systeminfo          # sistema operacional, domínio, último boot
```

Linux

```
whoami              # usuário atual
id                  # UID, GID e grupos
hostname            # nome da máquina
ip a                # interfaces e endereços IP
uname -a            # kernel e arquitetura
```

Os Módulos 3 e 4 aprofundam esses e dezenas de outros comandos, sempre com a pergunta "o que isso me mostra numa investigação?".

0.11 Ferramentas

Você não precisa dominar todas as ferramentas; precisa entender **as categorias** e o que cada uma responde. Quem entende o conceito aprende a ferramenta em dias; quem só decorou botões trava quando o fornecedor muda a interface.

Categoria	Para que serve	Exemplos
SIEM	Centralizar, normalizar, correlacionar e consultar logs; gerar alertas.	Microsoft Sentinel, Splunk, QRadar, Elastic, Wazuh, Google SecOps
EDR / XDR	Telemetria detalhada de endpoints; detecção comportamental; resposta (isolar, matar processo).	Microsoft Defender for Endpoint, CrowdStrike Falcon, SentinelOne, Sophos
SOAR	Automatizar e orquestrar enriquecimento e resposta, com aprovação humana.	Shuffle, Cortex XSOAR, Splunk SOAR, Logic Apps
ITSM / Ticketing	Registrar, acompanhar e medir casos e SLAs.	ServiceNow, Jira Service Management, GLPI, TheHive
Threat Intelligence	Reputação e contexto de IOCs.	VirusTotal, AbuseIPDB, AlienVault OTX, MISP, URLhaus
Sandbox	Executar arquivos suspeitos em ambiente isolado e observar comportamento.	ANY.RUN, Hybrid Analysis, Joe Sandbox (sempre respeitando política de confidencialidade)
Análise de rede	Capturar e inspecionar tráfego.	Wireshark, tcpdump, Zeek, Suricata
Gestão de ativos (CMDB)	Saber o que existe, de quem é e quão crítico é.	ServiceNow CMDB, GLPI, planilhas heroicas

MOMENTO SOC

CMDB: 420 hosts.

EDR: 391.

SIEM: 437.

Scanner de vulnerabilidades: 408.

Planilha do cliente: 456.

Parabéns.

Antes de procurar o atacante, descubra quantos computadores existem na empresa.

ATENÇÃO

Serviços públicos como VirusTotal são excelentes para **consultar** um hash. **Enviar** um arquivo é outra história: o que você envia pode ficar disponível para outros usuários da plataforma. Um PDF de contrato "suspeito" enviado para análise pública é um vazamento feito pelo próprio SOC. Siga sempre a política da empresa.

0.12 Exercícios

Responda por escrito antes de consultar as respostas comentadas no fim do módulo.

1. Explique, com suas palavras, a diferença entre SOC e NOC. Dê um exemplo de situação que interessa aos dois.
2. Um alerta de "execução de ferramenta de acesso remoto" disparou porque o suporte técnico usou a ferramenta oficial para atender um usuário, com chamado aberto. Classifique e justifique.
3. Um alerta de "login a partir da Rússia" disparou, mas a análise mostra que o IP é de uma operadora brasileira e a base de geolocalização está errada. Classifique e justifique.
4. Diga se cada item é IOC, IOA ou TTP: (a) o domínio `atualiza-banco-seguro[.]com`; (b) `outlook.exe` iniciando `mshta.exe`; (c) "o grupo envia phishing de boleto, usa macro para executar PowerShell e rouba credenciais de navegador"; (d) um hash SHA-256; (e) um processo acessando a memória do LSASS.
5. Explique por que um IOC tem "prazo de validade".
6. Um alerta de severidade Alta ocorreu numa VM de testes desconectada da rede de produção; outro, de severidade Média, ocorreu num controlador de domínio. Qual você olharia primeiro e por quê?
7. Liste cinco ações que um N1 normalmente pode executar e cinco que normalmente exigem autorização ou outro nível.
8. Por que "Verificado e normal" não é uma documentação aceitável?
9. Qual a diferença entre um alerta e um incidente? Quem normalmente declara um incidente?
10. Você recebe um alerta de que o firewall de borda parou de enviar logs há 3 horas. Isso é um incidente de segurança? O que você faz?

0.13 Laboratório

LABORATÓRIO — Lab 0.1 — Preparando sua base de estudos

Objetivo: montar o ambiente mínimo para acompanhar os próximos módulos e ter sua primeira experiência com um log de segurança real.

Duração estimada: 1h a 1h30.

Parte A — Organização

- Crie um repositório privado (depois poderá torná-lo público) no GitHub chamado `soc-n1-estudos`. Ele será seu portfólio (Módulo 30).
- Dentro dele, crie as pastas `anotacoes/`, `labs/`, `runbooks/`, `playbooks/`, `queries/` e `casos/`.
- Crie um arquivo `anotacoes/modulo-00.md` e escreva, com suas palavras, as definições do glossário.

Parte B — Virtualização

- Verifique se seu computador suporta virtualização (no Windows: Gerenciador de Tarefas → Desempenho → CPU → "Virtualização: Habilitado").
- Instale o VirtualBox (gratuito). Não crie VMs ainda: o laboratório completo vem no Módulo 25, mas os módulos 3 e 4 já vão pedir uma VM Windows e uma Ubuntu.
- Recomendação mínima para o lab completo: 16 GB de RAM e 100 GB livres em SSD. Com 8 GB é possível, mas uma VM por vez.

Parte C — Seu primeiro evento de segurança

- No seu próprio Windows (máquina pessoal, **nunca** corporativa), bloqueie a tela (Win + L) e digite a senha errada três vezes. Depois entre normalmente.
- Abra o **Visualizador de Eventos** (`eventvwr.msc`) como administrador → Logs do Windows → Segurança.
- Clique em "Filtrar Log Atual" e filtre pelos IDs `4625` e `4624`.
- Abra um 4625 e anote: horário, nome da conta, tipo de logon, código de status/falha, nome da estação.
- Abra o 4624 seguinte e compare os campos.
- Se nenhum 4625 aparecer, a política de auditoria de logon pode estar desativada. Anote isso: você acaba de descobrir, na prática, que **sem configuração de auditoria não há evidência**.

Parte D — Primeiro "ticket"

- Em `casos/caso-000.md`, documente o que você fez como se fosse um alerta: resumo, data/hora, ativo, usuário, evidências (campos anotados), análise, classificação e conclusão.

NA VIDA REAL

Se o Lab 0.1 Parte C não mostrou nenhum 4625, parabéns: você já viveu o problema mais comum de SOC. O ataque pode até ter acontecido. O log é que não foi convidado.

0.14 Perguntas de entrevista

P: O que é um SOC?

Resposta fraca	Resposta boa
"É a equipe que cuida da segurança."	É a equipe, com processos e ferramentas, que monitora continuamente o ambiente, detecta atividade suspeita, analisa, documenta e coordena a resposta inicial, escalando quando necessário. Usa fontes como SIEM e EDR e trabalha com Runbooks, Playbooks e SLAs.

O que está sendo avaliado: Clareza sobre a função operacional e o ciclo detectar → analisar → responder/escalar.

P: Qual a diferença entre evento, alerta e incidente?

Resposta fraca	Resposta boa
"É tudo a mesma coisa, só muda a gravidade."	Evento é qualquer ocorrência registrada. Alerta é gerado quando eventos casam com uma regra; é uma hipótese a investigar. Incidente é quando se confirma ameaça ou comprometimento real à segurança, declarado conforme política, geralmente por N2/IR.

O que está sendo avaliado: Precisão de vocabulário e entendimento de que alerta não é conclusão.

P: O que é um falso positivo? E um benigno positivo?

Resposta fraca	Resposta boa
"Falso positivo é quando não é nada."	Falso positivo é quando a regra dispara, mas a atividade que ela descreve não ocorreu ou foi mal interpretada, por exemplo por GeoIP errado. Benigno positivo é quando a atividade realmente aconteceu, mas é legítima, como um scanner autorizado. Em ambos, documento a justificativa com evidência.

O que está sendo avaliado: Maturidade na classificação e no impacto disso para ajuste de regras.

P: Qual o papel de um N1?

Resposta fraca	Resposta boa
"Olhar os alertas e passar para o N2."	Monitorar a fila, fazer triagem, analisar e enriquecer alertas, fazer investigação inicial, seguir Runbooks e Playbooks, documentar, executar contenções autorizadas e escalar com evidência quando o critério é atingido. Também acompanhar a saúde das fontes de log.

O que está sendo avaliado: Se o candidato entende que N1 analisa, e não só repassa, e que não é pentester.

P: Qual a diferença entre IOC e IOA?

Resposta fraca	Resposta boa
"IOC é um vírus e IOA é um ataque."	IOC é um artefato que indica possível comprometimento, como hash, IP ou domínio; é reativo e perecível. IOA é um comportamento que indica ataque em andamento, como o Word iniciando PowerShell ofuscado, e independe da infraestrutura usada.

O que está sendo avaliado: Compreensão de detecção por artefato versus comportamento.

P: Qual a diferença entre severidade e criticidade?

Resposta fraca	Resposta boa
"São sinônimos."	Severidade é a gravidade da ameaça se for real; criticidade é a importância do ativo ou usuário para o negócio. A prioridade combina as duas, além da confiança na detecção.

O que está sendo avaliado: Capacidade de priorizar com base em risco, não só no rótulo do alerta.

P: O que você faria se não soubesse classificar um alerta?

Resposta fraca	Resposta boa
"Fecharia como falso positivo para não atrasar a fila."	Documentaria o que já analisei, as evidências e a dúvida específica, consultaria o Runbook/Playbook e, se continuasse sem critério seguro, escalaria ou pediria apoio ao N2 ou ao Lead dentro do SLA. Nunca fecharia sem justificativa.

O que está sendo avaliado: Honestidade, segurança operacional e respeito a processo.

P: O que é TTP?

Resposta fraca	Resposta boa
"É um tipo de malware."	Táticas, técnicas e procedimentos: descrevem como um adversário opera. Tática é o objetivo, técnica é o método, procedimento é a implementação específica. É a base do MITRE ATT&CK e é mais durável que IOCs.

O que está sendo avaliado: Familiaridade com a linguagem de ameaças e com o MITRE.

P: SOC e NOC são a mesma coisa?

Resposta fraca	Resposta boa
"Sim, os dois monitoram."	Não. O NOC monitora disponibilidade e desempenho; o SOC monitora segurança. Colaboram porque o mesmo sintoma, como pico de tráfego, pode ter causa operacional ou maliciosa.

O que está sendo avaliado: Visão de ecossistema e colaboração entre áreas.

P: Por que documentação é tão importante no SOC?

Resposta fraca	Resposta boa
"Porque o gestor pede."	Porque permite continuidade entre turnos, auditoria, revisão por N2, métricas, melhoria de regras e, em incidentes, sustenta decisões e eventual análise forense ou jurídica. Investigação não documentada, para o SOC, não aconteceu.

O que está sendo avaliado: Entendimento do valor operacional e legal do registro.

0.15 Erros comuns

Erro	Por que é um problema	Como evitar
Tratar todo alerta como incidente	Gera pânico, escalonamentos desnecessários e perda de credibilidade.	Alerta é hipótese. Analise antes de adjetivar.
Tratar todo alerta como ruído	É assim que o verdadeiro positivo passa despercebido no meio de 300 falsos.	Aplique o mesmo método a cada alerta, mesmo os "de sempre".
Achar que N1 é pentester júnior	Leva a ações ofensivas não autorizadas e a estudar a coisa errada.	Foque em fundamentos, logs, análise e processo.
Confundir severidade com prioridade	Olha a VM de teste antes do controlador de domínio.	Considere criticidade do ativo e confiança.
Fechar como "FP" sem explicar	Ninguém consegue revisar, ajustar a regra ou confiar na análise.	Sempre: o que foi verificado, qual evidência, por que é FP/BP.
Agir sem autorização	Pode derrubar serviço, destruir evidência ou ferir política.	Siga o Runbook; na dúvida, escale.
Não perguntar por vergonha	Erros silenciosos são os mais caros.	Pergunte com contexto: "analisei X e Y, fiquei em dúvida em Z".
Estudar ferramenta antes de fundamento	Você sabe clicar, mas não sabe o que está vendo.	Redes, SO e logs primeiro. Ferramenta depois.

0.16 Falsos positivos comuns (e confusões de classificação)

Este módulo não entra em regras específicas, mas já é hora de conhecer as **fontes clássicas** de falsos positivos e benignos positivos que você vai encontrar em qualquer SOC. Cada uma terá tratamento detalhado no Módulo 21.

Origem	Alerta típico que gera	Geralmente é
Scanner de vulnerabilidades	Port scan, tentativas de exploit, muitos logins	BP (se autorizado e na janela)
Backup	Grande volume de dados trafegando, acesso a muitos arquivos	BP
Contas de serviço	Logins em muitos hosts, falhas repetidas após troca de senha	BP ou problema operacional
Administradores	PowerShell, criação de serviços, uso de ferramentas administrativas	BP, se houver mudança/contexto
Ferramentas de monitoramento	Conexões frequentes a muitos hosts, WMI, SNMP	BP
Base de GeoIP desatualizada	Impossible travel, login de país incomum	FP
Parser quebrado	Campos trocados, usuário "N/A" em massa, IP de origem 0.0.0.0	FP (problema de ingestão)
Regra recém-criada sem ajuste	Centenas de alertas idênticos	FP/BP em massa; reportar para tuning

MOMENTO SOC

Alerta: Malicious PowerShell.

Analista novo: ATAQUE.

Analista experiente:

- Quem executou?
- Em qual host?
- Qual a command line?
- Qual o parent process?
- Foi administração?
- Há mudança aprovada?
- O usuário faz isso normalmente?
- Tem conexão externa?
- Tem persistência?

A diferença entre os dois não é paranoia. É contexto.

0.17 Na vida real

NA VIDA REAL — O primeiro mês

O que você imagina: caçar hackers internacionais em tempo real, com telas verdes e mapas piscando.

O que acontece: descobrir que o servidor do alerta não tem owner, que o owner registrado saiu da empresa em 2021, que a CMDB diz que ele é uma impressora, e que o time de infraestrutura "acha que é do financeiro".

Nada disso é perda de tempo. **Descobrir contexto é investigação.** Um N1 que sabe descobrir de quem é um ativo vale ouro.

NA VIDA REAL — Documentação

Runbook oficial para o alerta: "Em construção".

Data da última atualização: 2019.

Autor: alguém que você nunca conheceu.

É por isso que, a partir do Módulo 16, você vai aprender a **escrever** Runbooks. Um dia, o autor anônimo do procedimento abandonado vai ser você. Faça melhor.

0.18 Momento SOC

MOMENTO SOC

Cliente, 4 minutos depois do alerta abrir: "Fomos hackeados?"

Você, ainda lendo o primeiro log: ...

Resposta profissional: "Recebemos um alerta e estamos em análise. Até agora não há confirmação de comprometimento. Atualizo vocês até [horário] ou antes, se houver novidade relevante."

Não prometa, não especule, não minimize. Dê prazo e cumpra. (E confira na matriz de comunicação se você é quem deveria responder ao cliente.)

0.19 Checklist de domínio

Marque apenas o que você consegue explicar **sem consultar** o material:

- ☐ Explico o que é um SOC e o ciclo de vida de um alerta.
- ☐ Diferencio SOC, CSIRT, CERT, NOC, DFIR, Threat Hunting e CTI.
- ☐ Descrevo o papel de N1, N2, N3, Lead, IR, Hunter, Detection Engineer, SIEM Engineer e Manager.
- ☐ Sei listar o que um N1 faz, o que faz só com autorização e o que não faz.
- ☐ Explico a diferença entre evento, alerta, caso e incidente.
- ☐ Classifico corretamente VP, FP, BP, FN e VN, com exemplos.
- ☐ Diferencio IOC, IOA e TTP e sei por que IOC é perecível.
- ☐ Explico telemetria, evidência e contexto e por que são indispensáveis.
- ☐ Diferencio severidade de criticidade e sei como isso afeta a prioridade.
- ☐ Sei citar as principais fontes de log de um SOC e o que cada uma responde.
- ☐ Concluí o Lab 0.1 e documentei meu primeiro "caso".

0.20 Resumo do módulo

- O **SOC** monitora, detecta, analisa, documenta e coordena a resposta inicial. Convive com CSIRT, CERT, DFIR, Threat Hunting, CTI e NOC, cada um com uma pergunta diferente.
- O **N1** trabalha com nove verbos: monitorar, triar, analisar, enriquecer, investigar (inicialmente), documentar, executar procedimentos, conter quando autorizado e escalar. **Não é pentester júnior.**
- **Evento** é registro; **alerta** é hipótese; **caso** é onde a investigação vive; **incidente** é ameaça ou comprometimento real, declarado conforme política.
- Classificações: **VP** (malicioso real), **FP** (a regra ou o enriquecimento errou), **BP** (aconteceu, mas é legítimo). Sempre com justificativa.
- **IOC** é artefato perecível, **IOA** é comportamento, **TTP** é o modo de operar do adversário.
- **Severidade** fala da ameaça; **criticidade** fala do ativo. Prioridade combina os dois.
- Sem **telemetria** não há detecção; sem **contexto** não há interpretação; sem **evidência** não há conclusão; sem **documentação**, para o SOC, nada aconteceu.

0.21 Respostas comentadas dos exercícios

Exercício 1. O NOC cuida de disponibilidade e desempenho ("está funcionando?"); o SOC cuida de segurança ("está sendo abusado? é esperado?"). Um exemplo comum aos dois é um pico de tráfego de saída de madrugada: para o NOC pode ser saturação de link por backup mal agendado; para o SOC pode ser exfiltração de dados. Resposta boa menciona que as equipes precisam trocar informação para chegar à causa.

Exercício 2. Benigno Positivo. A regra acertou: a ferramenta de acesso remoto foi de fato executada. Porém, a execução é legítima, feita pelo suporte com a ferramenta oficial e com chamado aberto. Documentar: número do chamado, técnico, host, horário e confirmação de que a ferramenta é a aprovada. Se o alerta for recorrente, sugerir exceção controlada (por exemplo, para os hosts do suporte), nunca uma exceção global.

Exercício 3. Falso Positivo. A atividade descrita ("login a partir da Rússia") não ocorreu; o erro está no enriquecimento de geolocalização. A evidência é o ASN/WHOIS mostrando a operadora brasileira. Ação complementar: reportar ao responsável pela plataforma, porque GeoIP errado vai gerar mais falsos positivos e, pior, pode mascarar logins realmente estrangeiros.

Exercício 4. (a) **IOC** — domínio é artefato. (b) **IOA** — comportamento anômalo: cliente de e-mail iniciando `mshta.exe`, utilitário frequentemente abusado para executar scripts. (c) **TTP** — descreve o modo de operação do grupo, da entrada ao objetivo. (d) **IOC** — hash é artefato. (e) **IOA** — acesso à memória do LSASS é comportamento típico de roubo de credenciais (embora algumas ferramentas legítimas de segurança também o façam, o que exige contexto).

Exercício 5. Porque o atacante troca infraestrutura com facilidade e baixo custo: novos IPs, novos domínios, arquivos recompilados com hash diferente. Além disso, IPs são reaproveitados: um endereço malicioso de um provedor de nuvem pode ser atribuído a um cliente legítimo dias depois. Bloquear ou alertar para IOCs antigos gera falsos positivos e dá falsa sensação de proteção. Por isso IOCs devem ter data, fonte e prazo de revisão.

Exercício 6. Em geral, **o controlador de domínio**. Severidade é a gravidade da ameaça; criticidade é a importância do ativo. Um DC comprometido significa potencialmente todo o domínio comprometido, enquanto uma VM de teste isolada tem impacto limitado. Ressalva importante: confirme que a VM está realmente isolada (CMDB e realidade discordam com frequência) e siga a matriz de priorização do seu SOC, que pode considerar também a confiança da detecção.

Exercício 7. Normalmente pode: consultar SIEM, analisar árvore de processos no EDR, consultar reputação de indicadores, montar timeline, documentar e classificar, abrir/atualizar/escalar tickets, verificar saúde das fontes de log. Normalmente exige autorização ou outro nível: isolar endpoint, bloquear IP/domínio, resetar senha ou desabilitar conta, remover e-mails das caixas, comunicar clientes, coletar artefatos, encerrar sessões. Nunca: alterar regras em produção por conta própria, executar malware fora de ambiente apropriado, reiniciar servidores críticos, enviar arquivo confidencial para serviço público. A lista exata depende do seu SOC; o que importa é saber que ela existe e consultá-la.

Exercício 8. Porque não diz **o que** foi verificado, **onde**, **com que evidência** e **por que** a conclusão é "normal". Ninguém consegue revisar, auditar, reaproveitar a análise num alerta futuro ou confiar nela durante um incidente. Uma documentação mínima aceitável diria, por exemplo: "Falhas de login da conta X no host Y entre 02:12 e 02:17 originadas de NB-JPEREIRA (IP 10.20.30.45, confirmado via DHCP). Causa: credencial antiga salva em unidade mapeada após troca de senha às 18h do dia anterior (evento 4723 no AD). Sem logins bem-sucedidos suspeitos. Classificação: Benigno Positivo."

Exercício 9. Alerta é a notificação gerada por uma regra: uma hipótese que precisa ser analisada. Incidente é a confirmação (ou forte indício, conforme política) de ameaça ou comprometimento real à confidencialidade, integridade ou disponibilidade. A declaração de incidente costuma caber ao N2, Lead ou time de IR, conforme a política da organização. O N1 identifica os indícios, documenta e escala.

Exercício 10. Não é, por si só, um incidente de segurança confirmado, mas é um **problema sério de visibilidade**: durante essas 3 horas, qualquer atividade no perímetro está invisível para o SOC. Ações: verificar no SIEM se a fonte está de fato sem eventos (e não apenas com atraso de ingestão), executar o Runbook de saúde de integração, acionar o responsável (SIEM Engineer, time de rede ou fornecedor) conforme o procedimento, abrir ticket, registrar no handover e avaliar com o Lead se há motivo para suspeitar de ação intencional (um atacante desligando o log é um cenário real, embora a causa mais comum seja operacional).

Próximo módulo

Módulo 1 — Fundamentos de Redes. O módulo mais longo da trilha, e por bom motivo: quase todo alerta envolve dois endereços se comunicando. Vamos percorrer o modelo OSI camada por camada, o TCP/IP, o encapsulamento completo de um acesso a `https://empresa.com`, endereçamento e subnetting para SOC, ARP, VLAN, roteamento, NAT, DNS, DHCP, TCP, UDP, ICMP, os protocolos que mais aparecem em investigações, firewall, proxy, VPN, e os primeiros passos com Wireshark e tcpdump.